CS-E4740 - Federated Learning '26

L8 - Privacy in FL

Assoc. Prof. Alexander Jung

IMC Krems – Spring 2026

Calendar **Glossary** **Book** **GitHub**

Table of Contents

Motivation: Privacy in Federated Learning

Legal Framework: GDPR and EU AI Act

Toy Setting: Linear Least Squares

Gradient Inversion Attack

Defence: Differential Privacy

Privacy–Utility Trade-off

Summary

Learning Goals

After this lecture you will understand

- why the GDPR and EU AI Act require privacy protection in FL
- why sharing gradients can leak private data
- how to reconstruct a local dataset from observed gradients (gradient inversion attack)
- basic principles of DP as a defence
- the privacy–utility trade-off in FL

Table of Contents

Motivation: Privacy in Federated Learning

Legal Framework: GDPR and EU AI Act

Toy Setting: Linear Least Squares

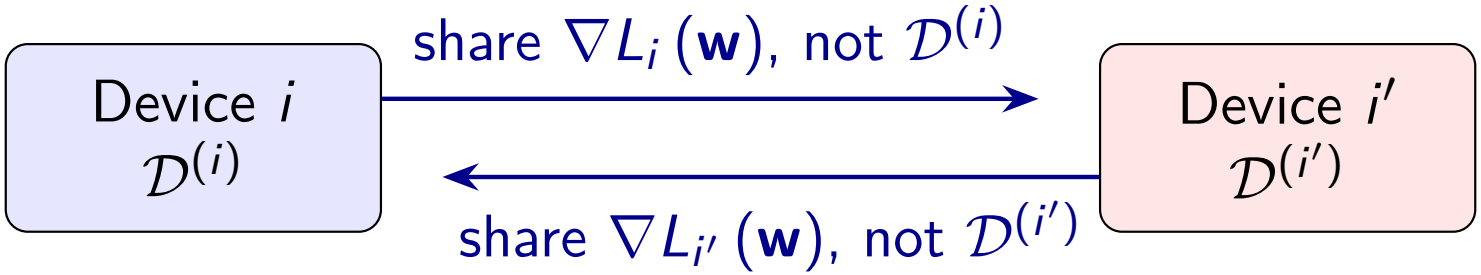
Gradient Inversion Attack

Defence: Differential Privacy

Privacy–Utility Trade-off

Summary

The Privacy Promise of FL



- FL algorithms exchange gradients or model parameters — **never raw data**
- Is this enough to guarantee privacy protection?

Spoiler: No. Gradients can reveal the local dataset — sometimes exactly.

Table of Contents

Motivation: Privacy in Federated Learning

Legal Framework: GDPR and EU AI Act

Toy Setting: Linear Least Squares

Gradient Inversion Attack

Defence: Differential Privacy

Privacy–Utility Trade-off

Summary

GDPR: Gradients Can Be Personal Data

The GDPR applies whenever **personal data** is processed.

Key insight: If gradients can be used to reconstruct personal data (as we will show), then gradients *themselves* qualify as personal data under the GDPR.

Relevant GDPR principles (Article 5):

- **Data minimisation** — collect and share only what is necessary. Sharing full gradients may violate this if aggregated statistics suffice.
- **Purpose limitation** — data (including gradients) may only be used for the purpose for which it was collected.
- **Integrity and confidentiality** — appropriate technical measures must protect personal data against unauthorised

EU AI Act: Privacy Requirements for High-Risk AI

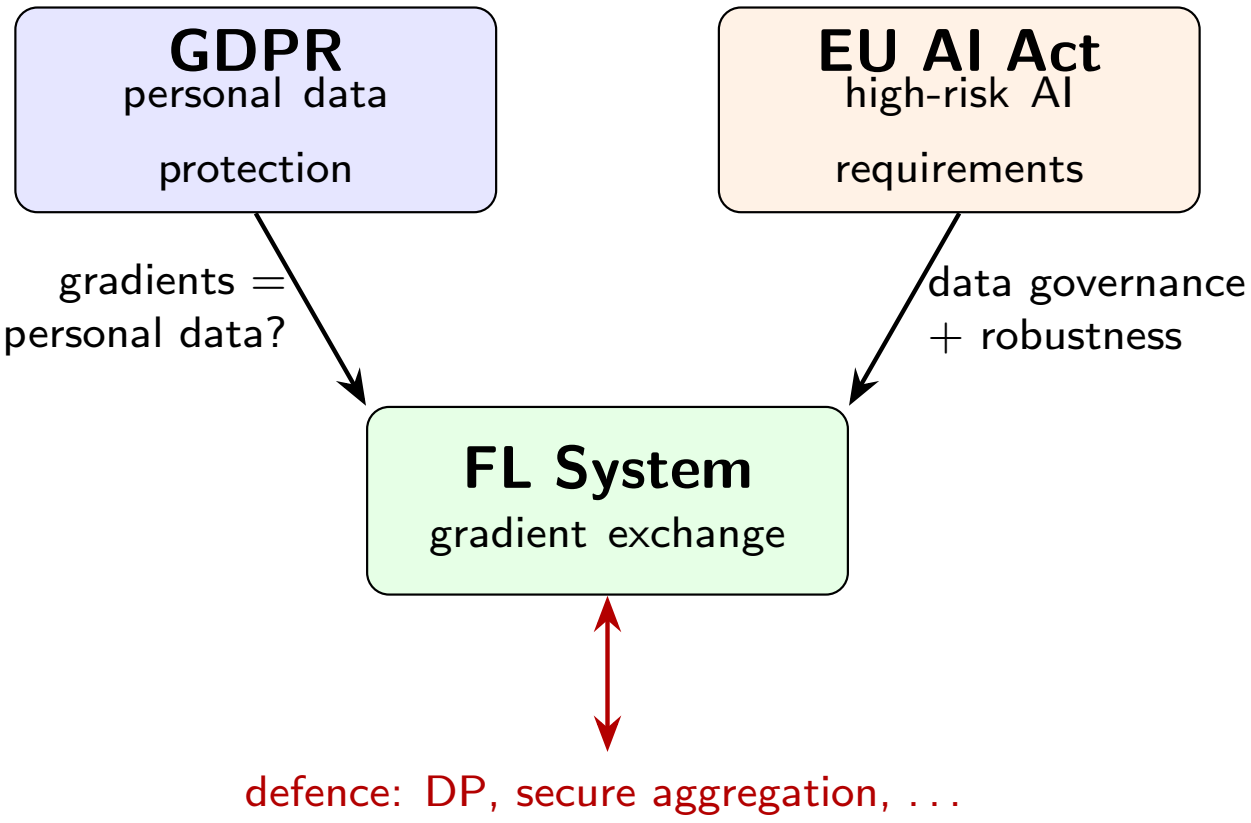
EU AI Act, Article 10 — Data and Data Governance

Training, validation and testing data sets shall be subject to data governance and management practices appropriate for the intended purpose of the AI system. [...] Those practices shall concern [...] relevant data-protection measures, including [...] anonymisation.

- The AI Act **applies simultaneously** with the GDPR
- High-risk AI systems must ensure data governance *throughout the lifecycle* (Article 15)
- FL systems processing personal data must demonstrate that gradient sharing does not undermine data protection

$\Rightarrow$ **Differential privacy** provides a formal, auditable

FL and the Law: Summary



- GDPR: gradients that leak personal data must be protected
- AI Act: high-risk systems need data governance and privacy by design
- Technical defences (DP) provide auditable compliance

Table of Contents

Motivation: Privacy in Federated Learning

Legal Framework: GDPR and EU AI Act

Toy Setting: Linear Least Squares

Gradient Inversion Attack

Defence: Differential Privacy

Privacy–Utility Trade-off

Summary

Setup: Single Node with Linear Model

Device i holds a private local dataset:

- feature matrix $\mathbf{X}^{(i)} \in \mathbb{R}^{m_i \times d}$
- label vector $\mathbf{y}^{(i)} \in \mathbb{R}^{m_i}$

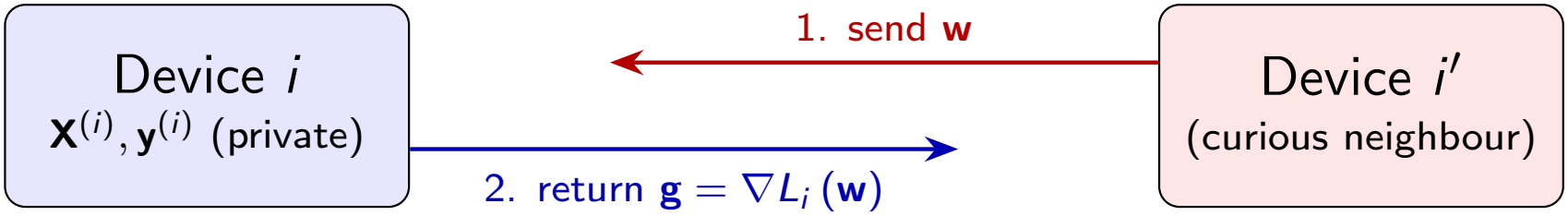
Local loss (mean squared error):

$$L_i(\mathbf{w}) = \frac{1}{m_i} \left\| \mathbf{X}^{(i)} \mathbf{w} - \mathbf{y}^{(i)} \right\|_2^2$$

Gradient at a given parameter vector $\mathbf{w}$:

$$\nabla L_i(\mathbf{w}) = \frac{2}{m_i} \mathbf{X}^{(i)^T} \left(\mathbf{X}^{(i)} \mathbf{w} - \mathbf{y}^{(i)} \right)$$

The FL Communication Step



Question: given $\mathbf{w}$ and the gradient $\mathbf{g} = \nabla L_i(\mathbf{w})$, can device i' recover the private data $\mathbf{X}^{(i)}, \mathbf{y}^{(i)}$?

Table of Contents

Motivation: Privacy in Federated Learning

Legal Framework: GDPR and EU AI Act

Toy Setting: Linear Least Squares

Gradient Inversion Attack

Defence: Differential Privacy

Privacy–Utility Trade-off

Summary

What Does the Gradient Reveal?

Recall:

$$\mathbf{g} = \nabla L_i(\mathbf{w}) = \frac{2}{m_i} \mathbf{X}^{(i)^T} \left(\mathbf{X}^{(i)} \mathbf{w} - \mathbf{y}^{(i)} \right)$$

Rewrite:

$$\mathbf{g} = \frac{2}{m_i} \mathbf{X}^{(i)^T} \mathbf{X}^{(i)} \mathbf{w} \; - \; \frac{2}{m_i} \mathbf{X}^{(i)^T} \mathbf{y}^{(i)}$$

The adversary knows $\mathbf{w}$ and observes $\mathbf{g}$, so they can compute:

$$\frac{2}{m_i} \mathbf{X}^{(i)^T} \mathbf{y}^{(i)} = \frac{2}{m_i} \mathbf{X}^{(i)^T} \mathbf{X}^{(i)} \mathbf{w} - \mathbf{g}$$

If m_i and the Gram matrix $\mathbf{X}^{(i)^T} \mathbf{X}^{(i)}$ are known (or can be estimated), the gradient leaks $\mathbf{X}^{(i)^T} \mathbf{y}^{(i)}$.

Multiple Gradients $\Rightarrow$ Full Reconstruction

Suppose the adversary queries d linearly independent parameter vectors $\mathbf{w}_1, \ldots, \mathbf{w}_d$ and observes the corresponding gradients $\mathbf{g}_1, \ldots, \mathbf{g}_d$.

Stack into matrices:

$$\mathbf{W} = \big(\mathbf{w}_1, \ldots, \mathbf{w}_d\big) \in \mathbb{R}^{d \times d}, \qquad \mathbf{G} = \big(\mathbf{g}_1, \ldots, \mathbf{g}_d\big) \in \mathbb{R}^{d \times d}$$

Then:

$$\mathbf{G} = \frac{2}{m_i} \mathbf{X}^{(i)^T} \mathbf{X}^{(i)} \mathbf{W} \; - \; \frac{2}{m_i} \mathbf{X}^{(i)^T} \mathbf{y}^{(i)} \, \mathbf{1}^T$$

With d gradient observations, the adversary can solve for both $\mathbf{X}^{(i)^T} \mathbf{X}^{(i)}$ and $\mathbf{X}^{(i)^T} \mathbf{y}^{(i)}$.

If $m_i \leq d$, the local dataset $(\mathbf{X}^{(i)}, \mathbf{y}^{(i)})$ can be **reconstructed exactly** (up to row permutation).

Exact Reconstruction: The $m_i = 1$ Case

Simplest case: device i has a single data point $(\mathbf{x}, y) \in \mathbb{R}^d \times \mathbb{R}$.

The gradient becomes:

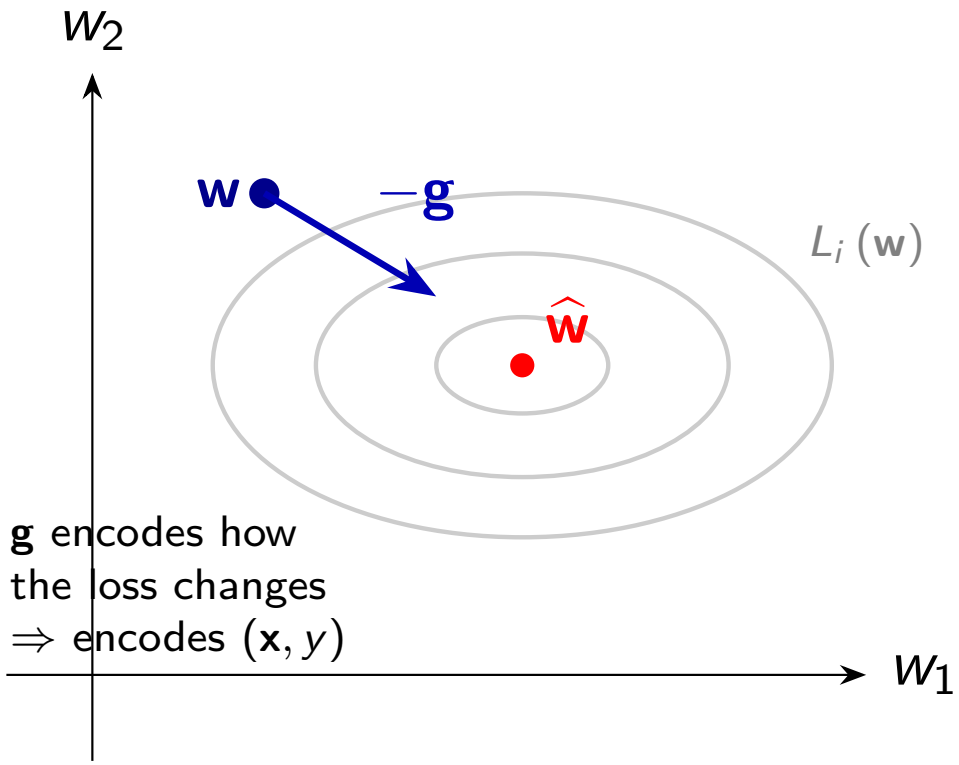
$$\mathbf{g} = 2\,\mathbf{x}\left(\mathbf{x}^T\mathbf{w} - y\right) = 2\left(\mathbf{x}^T\mathbf{w} - y\right)\mathbf{x}$$

The adversary knows $\mathbf{w}$ and observes $\mathbf{g}$:

1. **Direction** of $\mathbf{g}$ reveals $\mathbf{x}$ (up to sign): $\mathbf{x} \propto \mathbf{g}$
2. **Norm** of $\mathbf{g}$ together with direction reveals the scalar $(\mathbf{x}^T\mathbf{w} - y)$
3. Combining both: $y = \mathbf{x}^T\mathbf{w} - \frac{\|\mathbf{g}\|}{2\|\mathbf{x}\|}$

A single gradient from one data point leaks the data point completely.

Geometric Intuition



The gradient $\mathbf{g} = \nabla L_i(\mathbf{w})$ points toward the loss landscape shaped by the private data. Different data $\Rightarrow$ different gradient $\Rightarrow$ gradient identifies the data.

Table of Contents

Motivation: Privacy in Federated Learning

Legal Framework: GDPR and EU AI Act

Toy Setting: Linear Least Squares

Gradient Inversion Attack

Defence: Differential Privacy

Privacy–Utility Trade-off

Summary

Idea: Add Noise to the Gradient

Before sharing, device i adds calibrated noise:

$$\widetilde{\mathbf{g}} = \nabla L_i(\mathbf{w}) + \underbrace{\boldsymbol{\epsilon}}_{\text{noise}}, \qquad \boldsymbol{\epsilon} \sim \mathcal{N}(\mathbf{0}, \sigma^2 \mathbf{I})$$

- The adversary now observes $\widetilde{\mathbf{g}}$ instead of the true gradient
- Reconstruction becomes **noisy**: the more noise, the less leakage
- But: too much noise $\Rightarrow$ the gradient is useless for learning

Core trade-off: privacy (large σ) vs. utility (small σ).

Differential Privacy (Informal)

A mechanism $\mathcal{M}$ is (ε, δ)-**differentially private** if for any two datasets $\mathcal{D}^{()}$ and $\mathcal{D}^{(')}$ differing in one data point, and any set of outputs S:

$$\Pr\left[\mathcal{M}(\mathcal{D}^{()}) \in S\right] \;\leq\; e^{\varepsilon} \Pr\left[\mathcal{M}(\mathcal{D}^{(')}) \in S\right] + \delta$$

- ε: privacy budget (smaller = more private)
- δ: failure probability (typically $\delta \ll 1/m$)
- Removing or changing one data point barely changes the output distribution

Gaussian Mechanism for Gradient Perturbation

To achieve (ε, δ)-DP for a gradient with **sensitivity** Δ:

$$\Delta = \max_{\mathcal{D}^{()}, \mathcal{D}^{(')}} \left\| \nabla L\left(\mathbf{w}; \mathcal{D}^{()}\right) - \nabla L\left(\mathbf{w}; \mathcal{D}^{(')}\right) \right\|_2$$

Add Gaussian noise with standard deviation:

$$\sigma \ \geq \ \frac{\Delta \sqrt{2 \ln(1.25/\delta)}}{\varepsilon}$$

For our linear model:

$$\nabla L_i\left(\mathbf{w}\right) = \frac{2}{m_i} \mathbf{X}^{(i)^T} (\mathbf{X}^{(i)} \mathbf{w} - \mathbf{y}^{(i)})$$

Sensitivity depends on the **maximum norm** of individual data points and the parameter range.

Gradient Clipping + Noise (DP-SGD)

In practice, we combine two steps:

1. **Clip** each per-sample gradient to bound C:

$$\bar{\mathbf{g}}_r = \mathbf{g}_r \cdot \min\left(1,\ \frac{C}{\|\mathbf{g}_r\|_2}\right)$$

2. **Add noise** proportional to C:

$$\widetilde{\mathbf{g}} = \frac{1}{m_i} \sum_{r=1}^{m_i} \bar{\mathbf{g}}_r \ + \ \mathcal{N}\left(\mathbf{0},\ \sigma^2 C^2 \mathbf{I}\right)$$

M. Abadi et al., *Deep Learning with Differential Privacy*, CCS 2016.
https://doi.org/10.1145/2976749.2978318

Table of Contents

Motivation: Privacy in Federated Learning

Legal Framework: GDPR and EU AI Act

Toy Setting: Linear Least Squares

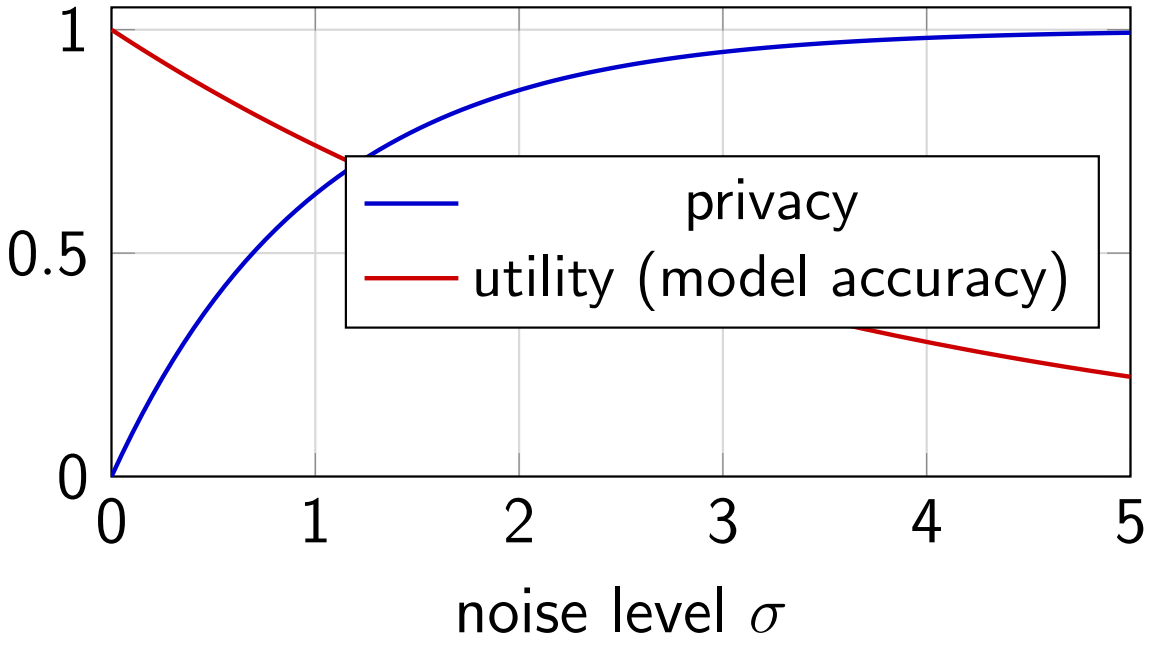
Gradient Inversion Attack

Defence: Differential Privacy

Privacy–Utility Trade-off

Summary

Effect of Noise on Learning



- **More noise** ($\sigma \uparrow$): better privacy, worse model
- **Less noise** ($\sigma \downarrow$): better model, more leakage
- The right σ depends on the application's privacy requirements

Back to Our Toy Example

Reconstruction error when adversary tries to invert a noisy gradient:

$$\widetilde{\mathbf{g}} = \mathbf{g} + \boldsymbol{\epsilon}, \qquad \boldsymbol{\epsilon} \sim \mathcal{N}(\mathbf{0}, \sigma^2 \mathbf{I})$$

For the single data point case ($m_i = 1$):

- $\sigma = 0$: adversary recovers $(\mathbf{x}, y)$ exactly
- $\sigma > 0$: reconstruction error $\mathbb{E}\left[\|\hat{\mathbf{x}} - \mathbf{x}\|^2\right] \propto \sigma^2$
- Large σ: gradient is pure noise, no information leaks

The noise σ must be chosen large enough that reconstruction becomes infeasible, but small enough that FL still converges.

Table of Contents

Motivation: Privacy in Federated Learning

Legal Framework: GDPR and EU AI Act

Toy Setting: Linear Least Squares

Gradient Inversion Attack

Defence: Differential Privacy

Privacy–Utility Trade-off

Summary

Summary

- **Gradient leakage.** Sharing $\nabla L_i(\mathbf{w})$ can reveal the private dataset $(\mathbf{X}^{(i)}, \mathbf{y}^{(i)})$ — exactly in the $m_i \leq d$ regime.
- **Linear model as worst case.** The gradient of linear least squares is a *linear* function of the data $\Rightarrow$ inversion is a system of linear equations.
- **Differential privacy.** Adding calibrated noise (ε-DP) provably limits what any adversary can learn, at the cost of reduced model accuracy.
- **Trade-off.** Privacy budget ε controls the privacy–utility trade-off; smaller ε = more private but noisier.
- **Legal compliance.** The GDPR treats reconstructible gradients as personal data; the EU AI Act requires data